

< ↺ ☆ Systemic Fraud: Interactions API Bypasses Paid Retention Policies & UI Deletion (CWE-459)

+1

Hotlists

Mark as Duplicate

🔔

⋮

Comments (4)Dependencies (0)Duplicates (0)Blocking (0)Resources (10)

WAI

Customer Issue

P4

+ Add Hotlist

 STATUS UPDATE No update yet.

 DESCRIPTION

bu...@google.com created issue on behalf of gabor_gabor@freemail.hu #1

Sep 22, 2026 03:28PM

⋮

Summary: Systemic Fraud: Interactions API Bypasses Paid Retention Policies & UI Deletion (CWE-459)

Program: Google VRP

URL: https://aistudio.google.com/

Vulnerability type: Sensitive data exposure

Details

Description: !!! MANDATORY NOTICE TO HUMAN REVIEWER !!! Do not close this report with an automated triage bot. Closing this as "Intended Behavior" constitutes a formal corporate admission of consumer fraud, GDPR Article 17 violations, and financial deception against paying Enterprise customers. The Vulnerability (The 3-Layered Fraud Architecture): Forensic testing of the Google AI Studio, Google Drive Trash, and the Gemini API log settings proves that Google's architecture is structurally incapable of executing a genuine data purge, resulting in a three-layered systemic fraud:

1. The UI Deception (Pointer Unlinking): The AI Studio UI guarantees that deleted chats "cannot be recovered." In reality, the system performs no backend database purge. It merely moves a client-side .json pointer file to the Google Drive Trash, leaving the raw prompt payload active on the Interactions API backend.
2. The Backend Zombie Persistence: Emptying the Drive Trash removes the pointer, blinding the UI. However, if a user utilizes the official Google Drive Recovery tool to restore the discarded .json pointer days or weeks later, the AI session instantly resurrects in milliseconds. This is empirical proof that the backend "hot storage" never received a cascade-delete signal.
3. The Financial Scam (Bypassing Paid Retention TTL): In the AI Studio Gemini API log settings, paying customers can configure strict data retention timeframes (e.g., 7 days instead of the 55-day default). However, because the Interactions API backend operates in a disconnected silo from the Drive UI, it ignores these rules. If a user pays for a 7-day retention policy, deletes a chat, empties the trash, and then restores the .json pointer on Day 20 using the Drive Recovery Robot, the chat fully resumes. This proves the backend never executed the paid 7-day purge. Google is actively charging Enterprise customers for data governance and deletion features that the system mathematically fails to execute. Steps to Reproduce: Configure an active AI Studio project with a strict retention policy (e.g., 7 days) in the log settings. Create a chat session with sensitive prompts. Click "Delete permanently" in the UI (Observe the fraudulent warning). Empty the Google Drive Trash. Wait well beyond the configured TTL (e.g., wait 20 days). Use the Google Drive Recovery tool to restore the .json pointer. The chat resumes instantly with full memory, proving the paid retention policy was ignored and the backend data was never destroyed.

Attack scenario

Impact: This is a critical CWE-459 (Incomplete Cleanup) vulnerability. Google is systematically deceiving users (GDPR Art. 12 & 17) and actively defrauding enterprise customers by charging them for retention policies (TTL) that the backend fails to honor. I demand a substantive review by human legal and engineering teams, not a triage script.

Reporter  gabor_gabor@freemail.hu

Type  Customer Issue

Priority P4

Severity S4

Status

Won't fix (Intended behavior)

Access Default access View

Expanded Access?

Assignee

Verifier

Collaborators  ^

CC  ^
gabor_gabor@freemail.hu
wo...@google.com
Un-CC me

Code Changes --

Pending Code Changes --

Disclosure information --

Reporter e-mail --

Requested charity --

Found In --

Targeted To --

Report Analysis

Note: The feedback below was generated as part of an automated analysis of the submitted report. It is *NOT* part of the report that was submitted by the user.

Out of Scope

The report is out of scope for the selected VRP. Please review our program rules.

 **Képernyőkép 2026-09-06 191250.png** 

262 KB [View](#) [Download](#) 

COMMENTS

All comments 

↓ Oldest first

 **sp...@google.com** <sp...@google.com> [#2](#) Sep 22, 2026 03:29PM 

NOTE: This is an automatically generated email

Hi! Many thanks for sharing your report.

This email confirms we've received your message. We'll investigate the issue you've reported and get back to you once we have an update. In the meantime, you might want to take a look at the [list of frequently asked questions about Google Bug Hunters](#).

Also, if you have not already done so, create a profile on [the Google Bughunters site](#) if you'd like us to publicly recognize your contribution:

- [Leaderboard](#) – You'll be added here if we issue a reward for your report.
- [Honorable Mentions](#) – You'll be added here if you are not in the Hall of Fame, but we file a security vulnerability bug based on your report.

Note that we only act on reports concerning vulnerabilities or technical security problems in one of our products. This is not the correct channel if you need to resolve a problem with your account, or want to report non-security bugs or suggest a new product feature.

Cheers,
Google Security Bot

[Follow us](#) on Twitter!

 **sp...@google.com** <sp...@google.com> [#3](#) Sep 22, 2026 03:29PM 

Status: Won't Fix (Intended Behavior).

NOTE: This is an automatically generated email

Our Vulnerability Reward Programs (VRPs) are built on key pillars of respect, constructive collaboration, and good faith to ensure a professional environment. These principles are formalized in our [Code of Conduct](#) which all participants are expected to uphold.

Verified In

In Prod 

A review has determined that activity associated with your account is inconsistent with these principles and constitutes a **violation of the Code of Conduct**.

Therefore, in line with our stated enforcement policy, **your account has been permanently excluded from our VRPs, and we will no longer review or act on any new submissions from your account, including this one**. Please be aware that we will not see any replies to this or other future reports. This action is final and not open to appeal.

For a detailed explanation of our community standards and prohibited behaviors, please refer to the full [Code of Conduct](#) document.

Sincerely,
Google Security Bot



gabor_gabor@freemail.hu <gabor_gabor@freemail.hu> [#4](#)

Sep 23, 2026 04:35AM ⋮

Google's AI Studio "Delete" is a 3-layer fraud. Paid users are being scammed on retention.

Please read the architectural breakdown before commenting. I have spent a year documenting a systemic data retention fraud (CWE-459) inside Google AI Studio and Google Drive. I have the screenshots, the server logs, and the VRP admission (IssueTracker ID: 564680465) where Google auto-banned me in 60 seconds and explicitly labeled this fraud as "Intended Behavior."

Google is running a 3-Layer Deception Architecture:

Strike 1: The UI "Placebo" (The Illusion) When you click "Permanent Delete" in AI Studio, the UI warns you the data is irreversibly destroyed. This is a lie. The backend database receives ZERO deletion flags. The system merely moves a client-side .json pointer file into your Google Drive Trash. The chat vanishes from your screen, giving you the illusion of privacy.

Strike 2: The Backend Zombie (The Recovery Robot) If you empty your Drive trash, the .json pointer is gone, and the UI says "Chat not found." But the backend "hot storage" (Interactions API) was never touched! If you use Google's official Drive Recovery Tool to resurrect that discarded .json pointer weeks later, the AI Studio interface instantly re-binds to the backend. The "permanently deleted" chat resurrects in milliseconds with 100% of its token history and system prompts.

Strike 3: The Enterprise Financial Scam (The Smoking Gun) In the "Gemini API log settings," Workspace/Enterprise users pay premium fees to set strict, custom data retention policies (e.g., 7 days, 14 days, instead of the 55-day default). But here is the mathematical checkmate: A paying user sets a 7-day retention policy and deletes a chat. They empty the trash. On Day 20 (well past the paid 7-day purge deadline), they use the Drive Recovery tool to restore the JSON pointer. The chat instantly resumes. This is physical proof that the backend NEVER executed the 7-day purge. Google's backend completely ignores the paid TTL settings.

Google is actively charging enterprise customers for data governance and 7-day retention features that their disconnected architecture physically fails to execute. They are hoarding proprietary corporate data indefinitely while selling a "Permanent Deletion" placebo.

The evidence, screenshots of the log settings, and the VRP censorship trail are archived here: <https://medium.com/@istokovicsgyorgy79>

<https://us1.discourse-cdn.com/spiceworks/original/4X/b/b/9/bb96356a76717b0724eed61c7854820da94c1375.jpeg>

Fun fact: I just submitted the evidence showing that Google also bypasses the PAID retention TTLs (0-day / 7-day limits) for Enterprise customers. The VRP bot closed it in 60 seconds as 'Intended Behavior'. Google just officially admitted in writing that scamming paying Enterprise customers with fake deletion features is a deliberate corporate policy! You can't make this up! 🤔

https://github.com/istokovicsgyorgy79-jpg/CanusLupus/blob/main/Systemic%20Fraud_%20Interactions%20API%20Bypasses%20Paid%20Retention%20Policies%20%26%20UI%20Dele

<https://medium.com/@istokovicsgyorgy79>

Subject: CRITICAL LEGAL NOTICE: Escalation to DPC & NOYB Confirmed – Scope Expanded to Intentional Enterprise Corporate Fraud To the Google Legal Department, Engineering Leads, and Assigned Counsel, Let this comment serve as formal notification that the evidentiary chain has officially closed and the regulatory filing is complete:

Regulatory Bodies Officially Served: The full supplementary forensic package—documenting the architectural bypass of paid enterprise retention TTLs, the stateful Interactions API backend persistence, and your VRP team’s formal admission of "Intended Behavior" (Ticket #564878654)—has been officially submitted to: The Irish Data Protection Commission (DPC) under active Case Reference: DPC-1-2808-033241-97b448fd-004d-42bd-83a5-ead8b0f9dadd. NOYB (European Center for Digital Rights) for coordinated European enforcement.

Legal Scope Officially Expanded to Corporate Fraud: The upcoming civil litigation will no longer be limited to statutory GDPR Article 17 and Article 5 violations. Based on forensic testing proving that Google actively collects premium fees from Enterprise/Workspace clients for custom data retention policies (e.g., 7-day TTL) while the backend consciously ignores them, the court action now incorporates charges of deliberate, systemic corporate fraud, contractual bad faith (SLA breach), and deceptive trade practices. By officially labeling this persistent backend retention as "Intended Behavior," your own records have documented the mens rea (willful intent) required to establish intentional fraud before a court of law.

The Final Window for Out-of-Court Settlement: Understand the procedural reality: Once this lawsuit is formally docketed in court, it becomes an unsealed, permanent public record. At that moment: Any possibility of a confidential out-of-court settlement or NDA is permanently extinguished. The discovery process will mandate the immediate production of internal communications, Slack logs, and backend database audits. The corporate fallout among paying enterprise clients will be irreversible. If Google LLC wishes to avoid a devastating public trial, multi-million-euro statutory fines, and global reputational collapse, your Legal Department must contact me directly and initiate formal, pre-litigation settlement discussions immediately. The countdown is at zero. Either reach out privately to resolve this matter, or we will see each other in front of the judge. Sincerely, György Istókolics (Bitu79) istokovicsgyorgy79@gmail.com

-  **Képernyőkép 2026-09-22 230051.png** ⋮
- 392 KB [View](#) [Download](#) 
-  **Gmail - Subject_ New Forensic Evidence_ Google AI Studio _Delete_ Button is a 3-Layer Placebo – B2B Enterprise Compliance Fraud Documented (1).pdf** ⋮
- 260 KB [View](#) [Download](#) 
-  **DPC-1-2309-015147-970feb87-fd3a-4e34-a020-faf632858c9b (1).zip** ⋮
- 3.1 MB [Download](#) 